

Aggiornamenti OTA con Secure-Boot e Flash encryption sul dispositivo embedded ESP32

Irimie Fabio

Relatore: Prof. Fummi Franco

Università degli Studi di Verona
Dipartimento di Informatica

Anno accademico 2023/2024

1 Obiettivo

2 Aggiornamenti OTA (Over The Air)

- Modalità di aggiornamento
 - Aggiornamento in modalità sicura
 - Aggiornamento in modalità non sicura
- App Rollback

3 eFuse

4 Secure Boot

- Processo di avvio con Secure Boot

5 Flash Encryption

- Modalità di Flash Encryption
- eFuse rilevanti
- Processo di avvio con Flash Encryption

- Proteggere il dispositivo da accessi non autorizzati alla memoria e dalla manomissione software tramite le seguenti funzionalità:
 - **Flash Encryption:** Protegge i dati memorizzati nella memoria flash del dispositivo.
 - **Secure Boot:** Impedisce l'esecuzione di firmware non autorizzato
 - **Secure OTA (Over The Air):** Permette di aggiornare il firmware da remoto garantendo che il nuovo firmware sia autentico e non compromesso.

Aggiornamenti OTA (Over The Air)

Gli aggiornamenti OTA permettono di aggiornare il firmware senza dover collegare il dispositivo ad un computer.

Ci sono due modalità principali di aggiornamento e si distinguono in base alla vulnerabilità del dispositivo.

- **Modalità sicura:** Garantisce l'operabilità del dispositivo anche in caso di guasto durante l'aggiornamento. L'unico tipo di partizione che supporta questa modalità è:
 - Application
- **Modalità non sicura:** L'aggiornamento è vulnerabile a guasti e il dispositivo potrebbe non essere più operabile. Il tipo di partizioni che supportano questa modalità sono:
 - Bootloader
 - Partition Table
 - Partizioni di tipo Data (come NVS, FAT, etc.)

Vengono configurate le seguenti partizioni:

- ota_0
- ota_1
- ota_data: contiene informazioni sullo stato di boot

Durante l'aggiornamento, il nuovo firmware viene scritto nella partizione ota non attiva. Se l'aggiornamento è completato con successo, la partizione ota_data viene aggiornata per indicare che la partizione ota appena scritta deve essere utilizzata al boot successivo.

Se la partizione ota_data non contiene alcun dato il dispositivo esegue il boot dalla partizione factory.

Una partizione temporanea riceve i dati della nuova immagine e, una volta completato il trasferimento, l'immagine viene copiata nella partizione di destinazione.

Se l'operazione di copia viene interrotta potrebbero verificarsi problemi di boot.

L'App Rollback permette di tornare ad una versione precedente del firmware se la nuova versione non funziona correttamente per garantire la funzionalità del dispositivo. Il corretto funzionamento del dispositivo viene verificato tramite una funzione eseguita dopo l'aggiornamento del firmware.

- Se l'app funziona correttamente, viene impostato lo stato dell'app a `ESP_OTA_IMG_VALID`
- Se l'app non funziona correttamente, il dispositivo esegue il rollback alla versione precedente e imposta lo stato dell'app a `ESP_OTA_IMG_INVALID`
- Se l'impostazione `CONFIG_BOOTLOADER_APP_ROLLBACK_ENABLE` è abilitata e viene effettuato un reset, allora viene effettuato un rollback senza chiamare nessuna funzione nell'applicazione.

Gli eFuse sono memorie non volatili che possono essere programmate una sola volta. Sono organizzati in 4 blocchi da 256 bit:

- **Blocco 0:** Riservato per valori di sistema
- **Blocco 1:** Chiave per Flash Encryption
- **Blocco 2:** Chiave per Secure Boot
- **Blocco 3:** Riservato per valori dell'utente

Il Secure Boot verifica che ogni firmware eseguito sul dispositivo sia stato firmato correttamente. Per la firma viene usata la crittografia asimmetrica:

- **Chiave privata:** Mantenuta segreta e usata per firmare il firmware
- **Chiave pubblica:** Inserita negli eFuse del dispositivo per verificare l'autenticità del firmware

La firma è una struttura detta Signature Block (4Kb) che viene inserita alla fine del firmware e viene calcolata su tutti i byte dell'immagine.

Processo di avvio con Secure Boot

- 1 Il first stage bootloader, presente in ROM, verifica la firma del second stage bootloader con la chiave presente negli eFuse.
- 2 Se la firma è valida, il second stage bootloader viene eseguito, altrimenti il boot viene interrotto.
- 3 Il second stage bootloader verifica la firma del firmware con la chiave presente negli eFuse.
- 4 Se la firma è valida, il firmware viene eseguito, altrimenti si cerca un'altra immagine valida finchè non viene trovata o si esauriscono le immagini.

Flash Encryption

La Flash Encryption permette di crittografare la memoria flash del dispositivo. Una volta attivata, tutte le seguenti partizioni vengono crittografate:

- Second stage bootloader
- Partition table
- Partizione OTA Data
- Partizioni di tipo Application

Altre partizioni possono essere crittografate condizionalmente:

- Partizioni con la flag encrypted
- Il hash del bootloader se il Secure Boot è abilitato

Esistono due modalità di funzionamento della Flash Encryption:

- **Modalità sviluppo:** Permette di flashare nuove immagini non crittografate sul dispositivo e il bootloader le crittografa utilizzando la chiave memorizzata negli eFuse.
- **Modalità rilascio:** Non è possibile flashare nuove immagini non crittografate sul dispositivo, ma è necessario flashare immagini già crittografate.

I seguenti eFuse sono rilevanti per la Flash Encryption:

- `flash_encryption`: contiene la chiave di crittografia
- `DISABLE_DL_ENCRYPT` (1 bit): se abilitato disattiva la flash encryption mentre il dispositivo viene eseguito in modalità Firmware Download
- `DISABLE_DL_DECRYPT` (1 bit): se abilitato disattiva la flash decryption mentre il dispositivo viene eseguito in modalità UART Firmware Download
- `FLASH_CRYPT_CNT` (7 bit): indica se i contenuti della memoria flash sono stati crittografati.
 - Se un numero dispari di bit sono impostati a 1, i contenuti della memoria flash sono crittografati e devono essere decrittografati durante la lettura.
 - Se un numero pari di bit sono impostati a 1, i contenuti della memoria flash non sono crittografati.

Processo di avvio con Flash Encryption I

Supponendo che i valori degli eFuse siano nello stato iniziale, il processo di avvio con Flash Encryption è il seguente:

- 1 Al primo avvio, la memoria flash non è crittografata e il first stage bootloader esegue il second stage bootloader.
- 2 Il bootloader controlla il valore dell'eFuse `FLASH_CRYPT_CNT`. Siccome tutti i bit sono a 0 (stato di default), cioè un numero pari di bit impostati, il bootloader configura e attiva il *flash encryption block*.
- 3 Il bootloader utilizza la chiave memorizzata nell'eFuse `flash_encryption`. Se la chiave non è presente ne genera una nuova e la scrive nell'eFuse.
- 4 Il *flash encryption block* crittografa tutti i dati nella memoria flash. L'intero processo avviene via hardware e la chiave non è accessibile dal software.

Processo di avvio con Flash Encryption II

- 5 Il bootloader imposta il primo bit disponibile di `FLASH_CRYPT_CNT` a 1 per indicare che i dati nella memoria flash sono crittografati.
- 6 In base alla modalità:
 - In modalità `development`, il second stage bootloader abilita soltanto gli eFuse `DISABLE_DL_ENCRYPT` e `DISABLE_DL_CACHE` per permettere al bootloader in modalità `Firmware Download` di flashare binari crittografati. Inoltre i bit dell'eFuse `FLASH_CRYPT_CNT` non sono protetti in scrittura.
 - In modalità `release`, il second stage abilita i bit degli eFuse `DISABLE_DL_ENCRYPT`, `DISABLE_DL_DECRYPT` e `DISABLE_DL_CACHE` per impedire che il bootloader decrittografi i dati durante la modalità `Firmware Download`. Inoltre i bit dell'eFuse `FLASH_CRYPT_CNT` sono protetti in scrittura.

Processo di avvio con Flash Encryption III

- 7 Il dispositivo viene riavviato per eseguire l'immagine crittografata. Il second stage bootloader chiama il *flash decryption block* per decrittografare i dati della memoria flash e caricare i contenuti decrittografati in memoria.